

Information Security Policy.

Classification: [internal/Public/confidential]

Use one of the following according to the needs with confirmation of required parties

version	Approved by	Owner	Date last updated	Review frequency	Next review	Comments

Table of Contents

Purpose.....	1
Scope	1
Roles and responsibilities	2
ISMS policies and Objectives.....	2
Physical Security.....	3
Third-party Security	3
Security classifications.....	4
Security breach reporting.....	4
Monitoring and filtering	4
Risk assessment and treatment methodology	4

Purpose

The purpose of the following document is to outline Company Name's information with regards to the security management strategy. This offers a framework for protecting the Organization's valuable information assets and outlines the different roles, duties, and protocols that must be followed to guarantee information security.

Scope

All customer and organizational data, in any format, is subject to this policy. It applies to all workers, third-party vendors, and other parties who deal with information assets owned by [Company Name].

Context of information security

The ISMS Scope Document describes the context and extent of information security, including the internal and external elements influencing [Company Name]. Which organizational components and information systems are covered by the ISMS is made clear in this paper.

Roles and responsibilities

Role	Responsibilities
Information Security Group (ISG)	Oversee and approve security policy implementation Manage the ISMS framework and drive security efforts across the organization
Information Security Manager	Administer the ISMS Conduct security risk assessments Ensure adherence to security policies
System / Information Owners	Manage risks associated with their respective information assets and Ensure compliance with security policies and procedures
Line Managers	Enforce policy compliance in their teams Manage access rights and ensure secure use of company devices and systems
All Employees	Follow security policies and report any security incidents Request exceptions via the IT Helpdesk if needed

ISMS policies and Objectives

This document outlines the key Information Security Policies and Procedures to facilitate the secure management of information assets at [Company Name]. Every policy and practice will possess an objective that is directly associated with the clauses of ISO 27001 and will contribute to the safeguarding of the organization's data, systems, and activities.

Category	Policy/Procedure	Objective	Details
Access Control	Access Control Policy	Ensure that only authorized personnel can access sensitive data and systems.	Defines role-based access control (RBAC), multi-factor authentication (MFA), and regular access reviews. Aligns with clauses 9.1.1, 9.2.1, 9.4.1.
	Access Control Procedure	Implement access controls based on job roles and responsibilities.	Describes RBAC, MFA, regular access reviews.
Incident Response	Incident Response Policy	Enable prompt response and recovery from security incidents.	Outlines incident reporting process, response workflow, and post-incident review procedures. Aligns with clauses 16.1.5.
	Incident Response Procedure	Manage and respond to security incidents effectively.	Includes incident reporting, response workflow, post-incident review.
Risk Management	Risk Management Policy	Systematically identify, assess, and manage risks to information assets.	Details risk assessment process, risk register maintenance, risk treatment plans. Aligns with clauses 6.1.2.
	Risk Management Procedure	Identify, assess, and manage information security risks.	Describes risk assessment processes, risk register maintenance, treatment plans.

Data Classification	Data Classification Policy	Ensure data is handled according to its sensitivity level.	Specifies data classification categories (e.g., Public, Internal Use, Confidential) and handling requirements. Aligns with clauses 8.2.1.
	Data Classification Procedure	Classify and handle data based on sensitivity.	Specifies classification categories, handling requirements, and regular audits.
Business Continuity and Data Backup	Business Continuity and Data Backup Policy	Ensure the continuity of critical operations and data availability during disruptions.	Defines backup schedules, offsite storage, and disaster recovery procedures. Aligns with clauses 17.1.
	Business Continuity and Data Backup Procedure	Ensure continuity and recovery of critical business operations.	Outlines backup schedules, offsite storage, disaster recovery plans.
Change Management	Change Management Policy	Manage changes to IT infrastructure to minimize security risks.	Covers change approval processes, testing procedures, and deployment controls. Aligns with clauses 12.1.
	Change Management Procedure	Manage changes to IT systems and processes.	Describes change approval processes, testing, deployment controls.

Physical Security

Physical Security This section makes sure that [Company Name]'s employees, property, and belongings are protected from damage, theft, and unauthorized access. This involves adhering to established policies and procedures to manage physical access to buildings, protect important resources, and keep both staff and guests safe.

- **Access Control:** Secure access passes, such as keycards or badges, are required for all employees. Report missing passes right away.
- **Visitor Policy:** While in restricted areas, visitors must always be accompanied.
- **Facility Security:** To safeguard limited areas, use biometric systems, swipe cards, or keys to secure entry point

Third-party Security

Third-Party Protection This section explains [Company Name]'s approach to handling outside contractors, vendors, and service providers' security risks. Ensuring the integrity of the company's information systems and assets is contingent upon third-party compliance.

- **Third-Party Risk Assessments:** To make sure they continue to comply, all third parties that handle corporate data must go through risk assessments.
- **Confidentiality agreements:** Non-disclosure agreements should be required of vendors handling sensitive data.

- **Third-Party Security Compliance:** Independent contractors and vendors should be able to attest to the fact that they have followed all the Company's security guidelines, including but not limited to the following. SaaS and supplier security.

Security classifications

The Security Classification section makes sure that all information and data at [Company Name] is categorized based on how sensitive it is. When processing, storing, and exchanging information, proper classification helps to implement the right security controls to prevent unwanted access.

Classification	Definition	Examples	Requirements
Confidential	Any unauthorized publication might result in [Company Name] suffering major damage or in infringing the law.	Customer data, financial information	• Encrypt • Restrict access to authorized personnel only • Securely destroy after use
Internal	internal use only, not for public distribution	Internal reports, internal emails	• Limited to employees and contractors • - Use encryption during transmission
Public	Information that can be freely shared with the public	Marketing materials, press releases	• No restrictions on sharing • Online publishing

Security breach reporting

Security Breach Reporting This section outlines multiple processes for the prompt detection, reporting, and handling of security incidents and breaches. It guarantees that [Company Name] will be prepared to act quickly to contain, evaluate, and lessen the effect of such security occurrences.

- **Incident Reporting:** The IT Helpdesk should be notified right away of any security issues pertaining to systems. Reports of physical breaches must be made to the Chief Privacy Officer (CPO) or the Office Manager.
- **Response Protocol:** For information on data breaches and serious security incidents, consult the Data Protection Policy and the Incident Response Plan, respectively.

Monitoring and filtering

System Monitoring: All computer systems are monitored by the firm to make sure they adhere to the relevant regulations and security guidelines. Investigative logs are kept of any suspicious activity.

Risk assessment and treatment methodology

Risk Assessment & Methodology The formal identification, analysis, and risk management of [Company Name]'s information assets are covered in this section. It ensures that each possibility of risk is properly managed and that controls are implemented in a way that makes sense given the risk.

ISO 27001 Toolkit

Step	Description
Risk Identification	Determine any potential risks or weaknesses that might influence information security.
Risk Analysis	Analyze the likelihood and potential impact of identified risks
Risk Treatment	Decide how to mitigate, transfer, avoid, or accept each risk, based on business objectives
Monitoring and Review	monitor and evaluate the ISMS frequently to make sure it's still relevant and effective.